
Position: The Privacy-Auditability Paradox in Federated Learning: Why We Need Controllable Secure Aggregation

Runhua Xu¹ Guoan Wan¹ James Joshi²

Abstract

Federated Learning (FL) has emerged as the de facto standard for privacy-preserving machine learning, largely due to Secure Aggregation (SecAgg) protocols rendering individual user contributions cryptographically invisible to the server; we contend that this pursuit of *unconditional blind aggregation* has produced a systemic vulnerability, the **Privacy-Auditability Paradox**. By making individual updates indistinguishable in the aggregate, default SecAgg creates a “Sanitization Gap” in which input-level poisoning is undetectable, and a “Regulatory Dead Zone” in which compliance with the EU AI Act’s robustness and traceability mandates are structurally undermined. In this position paper, we argue that the community must transition from *blind secure aggregation* to **Controllable Secure Aggregation (CSA)**, in which privacy is not a binary state of secrecy but a programmable spectrum of cryptographic access. CSA replaces binary secrecy with fine-grained, policy-based governance built on a complementary stack of *functional encryption*, *zero-knowledge proofs*, and *threshold cryptography*, yielding “Verified Blindness”: the server remains blind by default but admits a consensus-bound, cryptographically regulated break-glass channel for auditing specific inputs. Adopting CSA is not merely a technical upgrade but a necessary condition for transforming FL from an unregulated academic prototype into a robust, compliant, and trustworthy privacy infrastructure.

¹School of Computer Science and Engineering, Beihang University, Beijing, China ²School of Computing and Information, University of Pittsburgh, Pittsburgh, PA, USA. Correspondence to: Runhua Xu <runhua@buaa.edu.cn>, James Joshi <jjoshi@pitt.edu>.

1. Introduction

Federated Learning (FL) has moved from research prototype to large-scale industrial deployment, including production systems at Google and Apple. A central enabler of this transition is *Secure Aggregation* (SecAgg) (Bonawitz et al., 2017; Bell et al., 2020; 2023; Ma et al., 2023): by combining secure multi-party computation (MPC) with masking-based cryptography, SecAgg guarantees that the central server observes only the sum of client model updates, not the individual contributions. This property is widely treated as the confidentiality baseline for federated systems, eliminating the server as a single point of disclosure and rendering individual gradients statistically indistinguishable within the aggregate (Mansouri et al., 2023; Chen et al., 2024).

However, we contend that this pursuit of *unconditional, un-auditable blindness*, rendering individual contributions cryptographically indistinguishable in the aggregate without auxiliary validation channels, has inadvertently given rise to a systemic survival crisis for the field. We note in passing that even this form of blindness is not a complete guarantee of input privacy in the presence of an active server (Boenisch et al., 2023); the case for richer auditing channels is therefore not in tension with the field’s actual privacy posture. We identify this crisis as the *Privacy-Auditability Paradox*.

Current FL secure aggregation protocols have established a trustless environment where the server is blinded to user inputs. While this shields honest users, it creates a *Sanitization Gap*: traditional defense mechanisms against poisoning attacks (e.g., Krum, Median) rely on non-linear inspection of updates, which is not tractable over linearly aggregated ciphertexts without auxiliary cryptographic machinery (Wang et al., 2022; Tian et al., 2022). Consequently, the *blind* server becomes a sanctuary for adversarial actors, where model poisoning and backdoor injections are indistinguishable from legitimate learning signals.

Furthermore, this mathematical blindness creates a *Regulatory Dead Zone*. The impending EU AI Act, specifically Article 15, mandates that high-risk AI systems must possess “resilience against attempts by unauthorised third parties to alter their use... including data poisoning”. Simultane-

ously, Article 12 requires technical documentation ensuring the traceability of the functioning of the system (European Parliament and Council of the European Union, 2024). Conventional SecAgg, which generates only aggregated model updates without governance, is inherently unauditabile and therefore potentially non-compliant by design.

Position Statement: We argue that privacy and auditability must no longer be treated as a zero-sum trade-off. We propose that the FL community must transition from *Blind Secure Aggregation* to *Controllable Secure Aggregation* (CSA), a paradigm where privacy is not a binary state of secrecy, but a programmable spectrum of cryptographic access.

We dissect the Privacy-Auditability Paradox and outline a design for CSA grounded in cryptographic primitives that go beyond simple access control. Specifically, we draw on Attribute-Based Functional Encryption (Pal & Dutta, 2021; Jain et al., 2023) and Decentralized Multi-Client Functional Encryption (Chotard et al., 2020; Nguyen et al., 2023; Li et al., 2023; Qian et al., 2024). These primitives allow the network to cryptographically enforce *who* can aggregate data (based on policy attributes) and *what* functions can be computed (e.g., weighted sums), without revealing raw data. Combined with Zero-Knowledge Proofs (ZKPs) (Garg et al., 2023; Wang et al., 2024b; Ma et al., 2024; Laufer et al., 2024; Wang et al., 2024a) for verifying the well-formedness of encrypted updates, CSA replaces *blind trust* with *verified blindness*, ensuring that FL can survive the transition from an academic prototype to a regulated, high-assurance global infrastructure.

Scope of Contribution. We do *not* claim that ABFE, DM-CFE, ZKPs, threshold cryptography, or blockchain ledgers are individually novel primitives; each has a substantial prior literature that we build upon. Our contributions are at the level of (i) *problem formulation*, naming the privacy-auditability paradox and framing it as a first-class FL systems-and-governance problem rather than a primitive-design problem; (ii) *conceptual separation*, distinguishing *verifiability* (was the aggregate computed correctly?) from *auditability* (was the input admissible and the actor accountable?); and (iii) *architectural synthesis*, proposing the four-pillar CSA stack that maps admission control, function binding, input validity, and governed provenance/audit onto a coherent design space. The paper is best read as an *evidence-backed architectural thesis* for future FL secure aggregation, not as a finished, deployment-ready protocol.

Conflict of Interest Disclosure. The authors declare no financial conflicts of interest related to this work.

2. The Privacy-Auditability Paradox

Federated learning has achieved widespread industrial adoption by promising a trustless architecture. Leveraging secure aggregation protocols based on secure multi-party computation and computational cryptography, current frameworks guarantee that the central server perceives solely the global aggregate of model updates (Bonawitz et al., 2017; Bell et al., 2020; 2023; Ma et al., 2023). This design provides an information-theoretic guarantee of indistinguishability for individual contributions.

However, we argue that the singular pursuit of *unconditional, un-auditable blindness*, rendering individual inputs cryptographically indistinguishable in the aggregate while providing no auxiliary inspection channel, has inadvertently engineered a systemic *lawless space*. We define this phenomenon as the **Privacy-Auditability Paradox**: The precise cryptographic mechanisms that shield honest users from a prying server simultaneously dismantle the system’s “immune system” (robustness) and its legal standing (accountability). We dissect this paradox across three critical dimensions: the *Security Paradox*, the *Compliance Paradox*, and the *Illusion of Verifiability*.

2.1. The Security Paradox

The fundamental premise of traditional cybersecurity is “defense through visibility” by identifying anomalies, which necessitates traffic inspection. SecAgg fundamentally severs this feedback loop, creating what we term a **Sanitization Gap**. By masking individual gradients Δw_i within a cryptographic sum $\sum(\Delta w_i + r_i)$, the protocol renders the server computationally blind to the semantics of user contributions.

This blindness grants malicious actors a strategic asymmetry known as the *Indistinguishability of Malice*. In a plaintext FL system, a malicious update is easily identifiable as a vector space outlier. Under blind SecAgg without auxiliary inspection mechanisms, however, the server is structurally unable to distinguish between a legitimate update with high variance and a *model replacement attack*. Adversaries can exploit the linearity of aggregation by applying a massive scaling factor λ to a malicious update Δw_{mal} . Because the server observes only the final sum, this boosted update mathematically overwhelms the contributions of honest clients, hijacking the global model direction without triggering cryptographic alarms (Cao et al., 2021; Uddin et al., 2025). Furthermore, SecAgg acts as a tunnel for *backdoor persistence*. Research indicates that the distinct spectral signatures of backdoor gradients, such as specific neuron activation patterns triggered by *Trojan* triggers, are smoothed out in the aggregate ciphertext, preventing the server from inspecting or sanitizing suspect gradients (Xie et al., 2019; Bagdasaryan et al., 2020; Xie et al., 2021; Nguyen et al., 2022b).

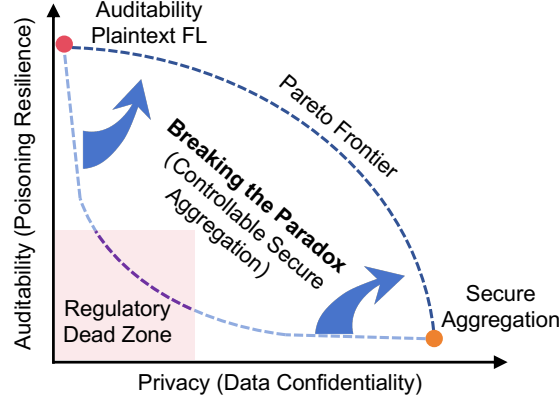


Figure 1. The Privacy-Auditability Landscape. Current secure aggregation standards (SecAgg) prioritize privacy at the total expense of auditability, creating a “regulatory dead zone.” Controllable Secure Aggregation (CSA) aims to transcend this zero-sum game by introducing cryptographic governance.

Crucially, this paradox creates severe *computational friction with byzantine robustness* under the default blind setting. The distributed systems community relies on robust aggregation rules, such as Krum, Trimmed Mean, or Geometric Median, to tolerate malicious participants (Lyu et al., 2022; Uddin et al., 2025). However, these algorithms inherently rely on *non-linear operations* (e.g., Krum computes pairwise Euclidean distances $\|x_i - x_j\|^2$ and sorting). Standard SecAgg protocols, built on computational cryptographic schemes or MPC, are computationally hostile to these operations. Implementing *secure Krum* inside MPC requires secure comparison protocols that are orders of magnitude more expensive than addition ($O(N^2)$ secure comparisons), rendering them impractical for most high-dimensional models at production scale. Under the default blind setting, system architects therefore face a stark trade-off: adopt expensive robust aggregation in the clear (exposing user privacy) or adhere to blind SecAgg without complementary mechanisms (admitting input-level poisoning).

2.2. The Compliance Paradox

If the security paradox represents a technical vulnerability, the compliance paradox represents an existential legal threat. Emerging regulations, most notably the *EU AI Act* and *GDPR*, are shifting the AI governance model from voluntary ethics to mandatory accountability. We argue that current blind SecAgg architectures provide only limited support for these mandates without auxiliary mechanisms because they enforce a state of *Epistemic Opacity*.

Federated learning introduces a *Double Black Box* problem: not only is the deep learning model opaque (the standard black box issue), but the *process* that created it is also epistemically opaque. The conflict is most acute regarding the mandate for *traceability*. Article 12 of the *EU AI Act* requires high-risk AI systems to maintain technical documen-

tation that ensures the *traceability of the functioning of the system* (European Parliament and Council of the European Union, 2024). In a standard SecAgg environment, the *chain of custody* for the model’s intelligence is severed by the aggregation protocol. The server receives only an ephemeral, encrypted aggregate, leaving it without cryptographic means to trace which client introduced biased, poisoned, or legally non-compliant data. This creates a **Liability Gap**: if a global model causes harm (e.g., an autonomous vehicle accident caused by a poisoned update), regulators cannot identify the malicious actor, and the platform operator cannot prove their own diligence, as the *evidence* was destroyed by the cryptographic summation.

Furthermore, *blind secure aggregation* protocols have only limited compatibility with the *Right to Erasure* (GDPR Art. 17), often framed as *Machine Unlearning* (Nguyen et al., 2025). To legally unlearn a specific user’s contribution from a global model S_t , the server must mathematically subtract that user’s update Δw_i . However, in a trustless SecAgg system, the server never possessed Δw_i in the first place. If a user submits a *correction vector* to be subtracted, the server faces a **Verification Gap**: it has no cryptographic means to verify if this correction vector corresponds to the original contribution or if it is a *poisoning attack in disguise* designed to degrade the model under the guise of privacy compliance. Thus, the default blind aggregation architecture leaves the legal right to be forgotten without cryptographic verifiability under default operation.

2.3. The Illusion of Verifiability

More importantly, we must address the conflation of *Verifiability* and *Auditability* that pervades recent literature. A growing body of work proposes *verifiable Federated Learning* (VFL) using cryptographic primitives like *Homomorphic Signature* (Johnson et al., 2002; Boneh & Freeman,

2011) or *Zero-Knowledge Proofs* (Wang et al., 2024b; Garg et al., 2023) to verify the correctness of aggregation. We contend that while VFL solves the problem of a malicious server, it fails to address the Privacy-Auditability Paradox.

Specifically, *verifiability* addresses the question: “*Did the server compute the sum correctly?*”, while *auditability* concerns whether “*the data used in the sum was valid, safe, and compliant.*” Current VFL schemes guarantee the integrity of the *aggregation process* while remaining completely blind to the *content*. A client can generate a validly authenticated, correctly formatted update that contains a backdoor trigger or violates data governance rules. VFL protocols will strictly verify that this poison was summed correctly into the global model. True auditability requires a paradigm shift beyond simple verification, which requires the ability to selectively inspect content under governance, leading us to the necessity of **Controllable Secure Aggregation**.

2.4. Relation to Auditable and Robust SecAgg

Recent work has begun to harden secure aggregation along individual subproblems, and it is important to delineate how CSA relates to these lines. *RoFL* (Lycklama et al., 2023) attaches zero-knowledge range proofs to masked client inputs, enforcing per-client norm constraints before aggregation; this corresponds to one element of our Pillar III (input well-formedness) but does not provide admission control or a governed audit channel. *ELSA* (Rathee et al., 2023) achieves malicious-secure two-server aggregation with input validation, strengthening server-side correctness while leaving compliance and provenance governance unaddressed. *BREA* (So et al., 2021) attains Byzantine-resilient secure aggregation through secret-sharing combined with secure pairwise distance computation, partially closing the sanitization gap at a quadratic cost in client count; it is orthogonal to participation eligibility and provenance. *FedML-HE* and related HE-based FL systems (Jin et al., 2023) selectively encrypt sensitive layers with roughly 10–40× computational overhead, providing strong confidentiality but no native auditability or provenance tracking. Finally, post-hoc statistical filters (Han et al., 2026), “kick bad guys out”-style anomaly detection, add a defensive layer over the aggregate; these are heuristic in nature and are not cryptographically bound to client identity, function, or policy.

In contrast, CSA is not proposed as an alternative to any single one of these systems. It instead supplies an *architectural envelope* that can compose them: policy-governed participation, function binding, input validity, and break-glass-style governed auditing, the four mechanisms whose joint absence, rather than the deficiency of any one component, underlies the Privacy-Auditability Paradox.

3. Controllable Secure Aggregation

3.1. The CSA Paradigm: From Blindness to Governance

We formally define *Controllable Secure Aggregation (CSA)* as a protocol paradigm that enables fine-grained, policy-based control and result verification over the aggregation process while strictly maintaining the confidentiality of individual inputs against unauthorized entities. Unlike traditional Secure Aggregation, which enforces a binary “*all-or-nothing*” visibility model (Bonawitz et al., 2017; Bell et al., 2020; 2023; Ma et al., 2023) that leaves the aggregator blind to the provenance and validity of contributions, CSA introduces a *Cryptographic Governance Layer*: the server acts as an active *Policy Enforcer* that aggregates only updates which cryptographically demonstrate compliance with pre-defined mandates. This shift fundamentally alters the trust model of FL from “trust by blindness” to “trust by control and verification,” achieving a state of “verified and controlled blindness”.

3.2. Pillar I: Policy-Based Computation Control

The first pillar of the CSA framework addresses the challenge of *Identity and Access Control* within the encrypted domain. Standard FL protocols typically authenticate clients via Transport Layer Security (TLS), which validates possession of a signing key but fails to verify the semantic attributes required for high-stakes model contribution (e.g., professional certification or jurisdictional residency).

To resolve this, CSA incorporates *Attribute-Based Functional Encryption (ABFE)* (Boyen, 2013; Abdalla et al., 2020; Nguyen et al., 2022a). In this scheme, model updates Δw_i are encrypted not merely for a specific recipient, but under a rigorous access policy $\mathbb{P}$ embedded directly into the ciphertext structure. The aggregation server is provisioned with a functional decryption key associated with the aggregation function f . The mathematical properties of ABFE ensure that the server can derive the aggregate result $f(\Delta w_1, \dots, \Delta w_n)$ if and only if the attribute set $\mathcal{A}_i$ of the contributing ciphertexts satisfies the policy $\mathbb{P}$. Consequently, if a malicious or unqualified node attempts to inject a gradient, the cryptographic evaluation inherently fails, and the update is mathematically excluded from the global model. This mechanism enforces participation eligibility at the ciphertext level, ensuring the model is derived exclusively from policy-compliant sources without exposing client identities.

3.3. Pillar II: Transparent Computation

While ABFE restricts participation and controlled computation, it does not inherently constrain the server’s computational behavior nor prevent it from isolating specific users.

To enforce *Computational Transparency* without relying on a fully Trusted Third Party, CSA employs *Decentralized Multi-Client Functional Encryption (DMCFE)* (Chotard et al., 2020; Qian et al., 2024) as its second pillar. In this approach, the master secret key is not held by a central authority but is distributed among the clients themselves. This distribution enforces strict *Function Binding*, where the server acts solely as an aggregator rather than a decryptor. To compute the global update, the server must obtain partial functional decryption keys from the client cohort, which are cryptographically bound to a specific weighting vector α and training round label L . The server can recover the aggregated result $\langle \alpha, \mathbf{x} \rangle$ only by combining these specific partial keys. This structure mathematically prevents the server from deviating from the consensus protocol or executing Isolation Attacks to target specific users, as it lacks the requisite functional keys to decrypt individual vectors. Thus, the aggregation logic becomes transparent and binding, contingent on the cryptographic consensus of the network.

3.4. Pillar III: Computation Integrity

The third pillar addresses *Computation Integrity*, resolving the “Sanitization Gap” where valid identities might submit malicious data. Even authenticated clients may become compromised (Byzantine) or faulty, submitting malformed gradients that can degrade or poison the global model.

Since the server cannot inspect the raw encrypted gradients, CSA mandates the integration of *Zero-Knowledge Proofs (ZKPs)* (Wang et al., 2024b; Garg et al., 2023), specifically non-interactive arguments of knowledge (e.g., zk-SNARKs or Halo2). Accompanying each encrypted gradient $C_i = \text{Enc}(\Delta w_i)$, the client must submit a cryptographic proof π_i . This proof attests to the *Well-Formedness* of the update, verifying critical constraints such as the L2-norm bound ($\|\Delta w_i\|_2 \leq \tau$) to prevent scaling attacks, or proving that the gradient was generated by a certified training algorithm on valid local data. The server performs verification $\text{Verify}(\pi_i)$ prior to aggregation; if the proof fails, the update is instantly rejected. This establishes a “Don’t Trust, Verify” environment where the correctness of the computation is mathematically guaranteed without compromising data confidentiality.

3.5. Pillar IV: Auditability

The fourth and final pillar addresses the *Privacy-Auditability Paradox*, reconciling confidentiality with the legal mandates for traceability and accountability (e.g., EU AI Act).

We propose a mechanism for *Controlled De-anonymization* governed by (t, n) -Threshold Cryptography (Benhamouda et al., 2022; Xu et al., 2024) and immutable ledger technology (Qu et al., 2022; Zhu et al., 2023). Unlike standard

Secure Aggregation where updates remain permanently indistinguishable, CSA encrypts updates such that they are recoverable only under extreme, pre-defined conditions (e.g., a “Break-Glass” scenario). An *audit key* is fragmented into n shares and distributed among distinct, independent stakeholders (e.g., regulatory bodies, consumer advocates, and platform operators). The reconstruction of a specific, suspicious update $\Delta w_{i,t}$ requires a quorum of t parties to cryptographically consent. This mechanism transforms the system from a “Lawless Dark Room” into a “Glass Vault”, namely, secure against unilateral surveillance but transparent to authorized, consensus-based oversight. Furthermore, all critical governance events, including policy definitions and audit triggers, are logged on a blockchain to provide an immutable audit trail. This capability restores the “Chain of Custody” required for regulatory compliance, strictly differentiating CSA from backdoored systems by enforcing procedural governance through mathematics.

Governance as a First-Class Threat Model. The governance layer itself is treated as a first-class threat model rather than a trusted black box. CSA does not grant any single party, including the server, arbitrary per-client visibility: break-glass invocation requires *multi-party consent* under (t, n) -threshold cryptography, *separation of duties* across structurally independent custodians (e.g., regulators, consumer advocates, and platform operators), and produces an immutable on-chain audit-log entry tying every invocation to a specific, ex-ante policy. The design goal is *bounded, accountable visibility*, not discretionary surveillance; custodian collusion is an explicit attack surface, against which the threshold parameter t and the cross-jurisdictional separation of custodians are the principal defenses.

Three Tiers of Information Disclosure. To make the privacy trade-off explicit, we delineate three leakage tiers introduced by CSA relative to default blind SecAgg: (i) *default-round privacy*, unchanged from SecAgg, with per-client gradients cryptographically indistinguishable within the aggregate; (ii) *predicate-proof leakage*, bounded and newly introduced, in which ZK proofs reveal only the Boolean outcome of policy-class predicates over an update (e.g., “ $\|\Delta w_i\|_2 \leq \tau$ ”; “signed under an attribute set satisfying $\mathbb{P}$ ”), without exposing gradient values; and (iii) *exceptional audit leakage*, governed and newly introduced, in which selective decryption of a specific update is permitted only under (t, n) -threshold consent and produces an immutable audit-log entry tied to a pre-specified policy and reason. We therefore do not claim “privacy $\geq$ standard SecAgg” in absolute terms; rather, CSA argues for a governed shift from unconditional blindness to *accountable, limited visibility* with quantified leakage channels, in which the marginal information disclosed is procedurally constrained, predicate-restricted, and tamper-evidently logged.

Scope and Limitations. We close this section by bounding our claims. CSA should be read as an *enabling substrate*, not as an automatic guarantee that ML-layer problems disappear: robust aggregation, backdoor detection, and machine unlearning remain subject to false positives and negatives, distributional heterogeneity, and policy choices. The argument of this paper is narrower and structural, under default blind SecAgg, these downstream ML actions are difficult to justify, evidence, or audit because the system provides no cryptographic hook for controlled inspection or attribution. CSA installs those hooks under multi-party governance; it does not, and is not intended to, replace ML-side robustness, fairness, or unlearning research.

4. Feasibility Analysis: The Price of Trust

4.1. Computational and Communication Overhead

We acknowledge that the transition from *blind secure aggregation* to *Controllable Secure Aggregation* (CSA) imposes a non-trivial computational price. Replacing lightweight masking, which typically relies on efficient modular addition and pseudo-random number generation ($O(n)$ complexity), with advanced cryptographic primitives like *Attribute-Based Functional Encryption* (ABFE), *Decentralized Multi-Client Functional Encryption* (DMCFE) and *Zero-Knowledge Proofs* (ZKPs) fundamentally alters the resource landscape. Typically, DMCFE and ABFE introduces the overhead of bilinear pairing operations (e.g., on BN254 or BLS12-381 curves) (Chotard et al., 2020; Qian et al., 2024; Boyen, 2013; Abdalla et al., 2020; Nguyen et al., 2022a), while ZKPs require generating polynomial commitments, increasing computational complexity by orders of magnitude in naive implementations.

However, we argue that this overhead is rapidly converging toward practicality due to two parallel vectors of innovation. First, the *Algorithmic Software Vector* has evolved explosively. Protocols like Halo2 and Plonky2 have moved the field away from the heavy, trusted setup phases of early SNARKs. By supporting recursive proof composition, these protocols allow clients to aggregate proofs locally before transmission, effectively amortizing verification costs across training rounds (Wang et al., 2024b). Furthermore, modern DMCFE schemes have optimized the inner-product functional encryption kernel, enabling dynamic client membership without requiring costly global re-keying (Qian et al., 2024).

In addition, the *Hardware Acceleration Vector* is fundamentally reshaping edge capabilities. The primary bottlenecks in ZKP generation, namely, Multi-Scalar Multiplication (MSM) and Number Theoretic Transforms (NTT), share underlying mathematical structures with deep learning tensor operations. Consequently, modern Neural Processing

Units (NPUs) and Edge TPUs, originally designed for inference, are increasingly being repurposed to accelerate cryptographic proving speeds by factors of 10x-100x. The ubiquity of Trusted Execution Environments (TEEs) further allows for hybrid approaches, where partial verification is offloaded to secure hardware enclaves to reduce the pure cryptographic burden.

4.2. Evaluation Roadmap

To complement the qualitative outlook of §4.1, we sketch a concrete five-dimension roadmap along which the practical viability of CSA should be evaluated. Each dimension calls out an indicative order of magnitude from current literature rather than a fixed engineering target.

(1) Prover Time. Per-client proof generation is dominated by Multi-Scalar Multiplication (MSM) and Number-Theoretic Transform (NTT) work. Recursive proof systems such as Halo2 and Plonky2 today report seconds-scale proving for moderately sized circuits on commodity CPUs, with reported reductions of roughly 10–100× when MSM/NTT are offloaded to GPUs or NPUs (Wang et al., 2024b; Garg et al., 2023). For FL gradients of dimension $d \in [10^5, 10^7]$, the practically relevant figure is not absolute proving cost but the per-round amortized cost when proofs cover only a small policy predicate (e.g., a norm bound) rather than the full training computation.

(2) Proof Size and Verification Latency. Modern SNARKs over BN254 or BLS12-381 curves produce proofs in the kilobyte range with millisecond-scale verification on commodity servers, largely independent of witness dimension (Garg et al., 2023; Wang et al., 2024b). Verification scales benignly with the number of clients, which makes server-side checking the least concerning component of the CSA stack.

(3) Communication Expansion. ABFE/DMCFE ciphertexts are typically 2–10× larger than the plaintext gradient, and threshold-key shares add a fixed per-round overhead that scales with the number of custodians n rather than with the number of clients (Chotard et al., 2020; Qian et al., 2024). The aggregate communication footprint therefore remains within the same order of magnitude as standard masking-based SecAgg, bounded by a small multiplicative constant.

(4) Key-management and Dropout Tolerance. DMCFE supports dropout-tolerant partial decryption: if a subset of clients fail to respond, the server can still recover the aggregate over the surviving cohort provided their partial keys reconstruct the consensus functional key for the round (Qian et al., 2024; Nguyen et al., 2023). Threshold audit keys are independently refreshable across rounds. Asynchronous client participation remains an open engineering question

and should be reported explicitly in any future end-to-end evaluation.

(5) Migration from Existing SecAgg Pipelines. CSA is designed to be deployed *modularly* on top of existing SecAgg infrastructure rather than as a clean-slate replacement. A natural staged migration is: (a) layer ZK well-formedness proofs (Pillar III) onto existing masked SecAgg to obtain immediate input-level robustness; (b) introduce ABFE-based admission (Pillar I) for jurisdiction- or attribute-sensitive deployments; (c) replace masking with DMCFE function binding (Pillar II) where Sybil or isolation attacks are in scope; and (d) attach (t, n) -threshold break-glass auditing (Pillar IV) once governance custodians are in place. Each stage preserves backward compatibility, lowering the activation energy for production adoption.

4.3. Comparative Analysis: Blind vs. Controllable

To analyze the strategic trade-off, we present a comparative analysis between the current industry standard (Blind SecAgg) and our proposed CSA paradigm. As detailed in Table 1, the divergence is not merely technical but philosophical. Traditional SecAgg optimizes for *unconditional* privacy and low computational overhead ($O(n)$), effectively creating a *regulatory dead zone* where input-level poisoning is undetectable under default operation and legal compliance lacks cryptographic evidence. In contrast, CSA accepts a higher computational baseline, referred to here as the “Tax of Trust,” to restore the system’s immunity. By transitioning from coarse-grained identity checks to fine-grained ABFE and ZKPs, CSA trades the opacity of unconditional blindness for a sustainable governance model where privacy is the default, but auditability is a cryptographic guarantee.

4.4. Strategic Feasibility

Evaluating CSA solely through the lens of algorithmic efficiency constitutes a strategic myopia. We argue that the overhead introduced by ABFE and ZKPs should not be viewed as a performance bottleneck, but as a necessary *Compliance Tax*, namely, an operational prerequisite for deploying Federated Learning in high-stakes environments.

This trajectory mirrors the historical evolution of the World Wide Web. The transition from HTTP to HTTPS introduced tangible latency via SSL/TLS handshakes, yet it was universally adopted because the alternative (i.e., an unsecured and untrusted network) became fundamentally untenable for modern commerce. Similarly, as FL evolves from academic prototypes to critical infrastructure, the cost of cryptographic verification becomes an unavoidable price for trust. In the context of the *EU AI Act*, an FL system that maximizes throughput but fails to provide audit trails for high-risk applications is not merely flawed; it is a legal liability (European Parliament and Council of the European Union,

2024). Therefore, the community must recognize that while the computational cost of CSA is finite and decreasing (via hardware acceleration), the cost of non-compliance, namely, legal prohibition and loss of user trust, is infinite.

4.5. The Compliance Imperative

Current FL protocols operate in a regulatory vacuum, effectively engineering a state of non-compliance by design. In Table 2, we systematically map the conflicts between standard Secure Aggregation and the impending EU AI Act (AIA). We argue that while Blind SecAgg optimizes for secrecy, it fails to satisfy the *traceability* and *robustness* requirements essential for high-risk AI systems.

The most critical friction point concerns **Article 15 (Robustness)**. As noted in the table, blind SecAgg creates a *Sanitization Gap* where input-level poisoning is undetectable under default operation, leaving compliance with robustness mandates without cryptographic evidence. CSA resolves this by shifting from blind faith to verified computation, utilizing Zero-Knowledge Proofs (ZKPs) to enforce robustness constraints (e.g., gradient norm limits) *before* any data is aggregated.

Furthermore, regarding **Article 12 (Logging)** and **Annex IV (Provenance)**, traditional protocols destroy the chain of custody by design. CSA restores this via ABFE and the *Break-Glass* mechanism. This transforms the system from a black box into a glass vault, where individual contributions remain private by default but become chemically traceable during a forensic audit. Finally, regarding **GDPR Article 17**, CSA provides the only viable path for *Verifiable Machine Unlearning*. While blind protocols cannot prove a user’s data was removed, CSA allows an auditor to cryptographically verify the subtraction of a specific vector, satisfying the “Right to Verify” implicit in data protection laws.

5. Alternative Views

As with any proposal advocating for a fundamental architectural shift, the transition from *Absolute Blindness* to *Controllable Secure Aggregation* (CSA) invites significant epistemic friction. We anticipate three primary objections rooted in the current orthodoxy of the field: the cryptographic purism of backdoors, the ideological commitment to permissionless decentralization, and the pragmatic concern regarding computational overhead.

5.1. The Backdoor Misconception

The sharpest criticism of the CSA framework is that allowing any ability to decrypt individual updates, even for audit purposes, effectively creates a cryptographic backdoor. Critics argue that CSA revives the dangers of *key*

Table 1. Comparative Analysis: Traditional Secure Aggregation vs. Controllable Secure Aggregation (CSA)

Metric	Traditional Secure Aggregation (Current Standard)	Controllable Secure Aggregation (Proposed Paradigm)	Strategic Implication
Privacy Model	Unconditional Blindness Aggregate-level indistinguishability; no auxiliary input-level validation.	Accountable, Limited Visibility Privacy is the default; visibility is granted only via cryptographic warrant under multi-party consent.	<i>Trades “Opacity” for “Governance.”</i>
Poisoning Resilience	Severely Constrained Without auxiliary mechanisms, vulnerable to Sybil & model replacement due to sanitization gap.	High ZKPs enforce input validity; ABFE enforces identity legitimacy before aggregation.	<i>Restores the “Immune System.”</i>
Regulatory Compliance	Limited Support Provides no native evidence for EU AI Act Art. 15 (Robustness) or GDPR Art. 22 (Explanation).	Compliant by Design Supports cryptographic audit trails and verifiable machine unlearning.	<i>Enables legal survival.</i>
Comp. Cost	Low Mobile-friendly ($O(n)$ PRG + Addition).	Medium-High Requires ZKP Proving ($O(n \log n)$) + Bilinear Pairings.	<i>The “Tax” of Trust.</i>
Access Control	Identity-Based Coarse-grained (PKI); binary access.	Attribute-Based (ABFE) Fine-grained; policy-embedded computation (e.g., Region + Role).	<i>Enables Data Sovereignty.</i>

Table 2. Comparison of Regulatory Compliance: Current Blind Secure Aggregation vs. CSA Solution under the EU AI Act and GDPR.

EU AI Act Requirement	Current Status (Blind Secure Aggregation)	CSA Solution (Verifiable Governance)
Art. 15(4): Robustness	Limited Support. Cannot detect input-level poisoning under default operation; relies on blind faith without auxiliary mechanisms.	Compliant. ZK-Folding proves updates satisfy robustness constraints (e.g., Norm limits, valid gradient path) <i>before</i> aggregation.
Art. 12(1): Logging	Limited Support. No native logs of individual contributions; only global aggregates.	Compliant. “Break-Glass” mechanism enables retroactive, granular logging of malicious inputs for forensic analysis.
Annex IV: Provenance	Limited Support. Provides no cryptographic means to attribute model influence to specific clients.	Compliant. Attribute-Based Functional Encryption (ABFE) cryptographically binds model updates to specific data sources/attributes.
GDPR Art. 17: Erasure	Unverifiable. Provides no cryptographic means to confirm that a user’s contribution has been removed (“unlearned”).	Verifiable. User provides proof of erasure; “Break-Glass” allows auditor to verify the subtraction of that specific user’s vector.

escrow, introducing a single point of failure that state actors or malicious insiders could exploit for mass surveillance.

We contend that this critique suffers from a categorical error that fails to distinguish between a *hidden vulnerability* and a *transparent governance protocol*. A traditional backdoor is, by definition, a clandestine access path known only to the attacker or vendor, designed to bypass authentication. In stark contrast, CSA utilizes (t, n) -Threshold Cryptography (Benhamouda et al., 2022; Xu et al., 2024) to implement a *Break-Glass* mechanism. Under this protocol, the audit capability is not held by the server or any single entity. Instead, the private decryption key is fragmented into n shares and distributed among independent stakeholders (e.g., regulators, consumer advocates, and the platform operator). Decryption is a sociological and decentralized collabora-

tive event, requiring a cryptographic consensus of t parties, triggered only under verifiable conditions. This is not a backdoor; it is a transparent, governable *front door* analogous to a search warrant in the physical world.

Furthermore, we argue that the *status quo* (blind secure aggregation without auxiliary inspection) poses a much greater, though less visible, security risk; recent work has shown that even default blind aggregation does not, in practice, prevent an active server from extracting per-client information (Boenisch et al., 2023). By enforcing unconditional blindness at the aggregation layer, current protocols inadvertently create a *safe harbor for malware*. As demonstrated in the Security Paradox (Section 2), the inability to inspect gradients renders the system defenseless against actual malicious backdoors injected by attackers (e.g., Trojan trig-

gers) (Bagdasaryan et al., 2020; Bell et al., 2023). In a blind system, a malicious actor can implant a backdoor that remains persistent because the server has no cryptographic hooks for input-level auditing. CSA, by contrast, provides those hooks under governed conditions; we trade unverifiable blindness for accountable, limited transparency, a trade-off that, on net, enhances total system security.

5.2. The Decentralization Fallacy

The second major critique opposes introducing Policy-Based Access Control (via Attribute-Based Functional Encryption), arguing that it undermines the permissionless nature of federated learning. Proponents argue that FL should reflect Bitcoin’s open architecture, allowing any device to participate without centralized control, and that enforcing identity requirements would recentralize power.

This argument, though historically compelling, overlooks the operational realities of high-stakes AI. Permissionless participation may be acceptable for low-risk applications like keyboard prediction, but it becomes a serious liability in fields such as healthcare and finance. In these domains, a trustless architecture cannot mean relying on random, unverified participants. A medical diagnostic model trained on uncertified data from unknown nodes is not democratized; it is dangerously unreliable and vulnerable to Sybil attacks (Uddin et al., 2025).

We argue that *decentralization* should not be mistaken for *anarchy*. True data sovereignty means keeping data local, not eliminating rules. CSA maintains the decentralized architecture of data storage while adding a necessary *governance layer* to ensure integrity. For FL to evolve from an academic prototype into critical infrastructure, it must abandon the naive belief that all participants act in good faith. By enforcing strict, policy-based participation rules (e.g., only board-certified radiologists may update the cancer model), CSA transforms FL from a chaotic experiment into a robust, professional-grade ecosystem. Rather than betraying FL’s spirit, this evolution is its only path to avoiding regulatory obsolescence.

5.3. The Efficiency Critique

Finally, skeptics may argue that the computational overhead of CSA, particularly the bilinear pairings in DMCFE and proof generation in ZKPs (about 10× to 100× higher than plaintext), is prohibitive for edge devices.

We argue that assessing CSA solely through algorithmic efficiency reflects strategic myopia. First, this view overlooks hardware trends: on-device NPUs are increasingly optimized for the modular arithmetic used in modern cryptography. Second, and more importantly, the proper comparison is not with plaintext training but with *compliant*

training. Centralized training carries infinite privacy costs, while standard blind FL entails infinite liability costs.

Just as the internet moved from HTTP to HTTPS despite the initial latency of SSL/TLS handshakes, federated learning also should accept the computational overhead of CSA as a necessary *Compliance Tax*. It is the unavoidable cost of deploying safe, auditable AI in a regulated world.

6. Conclusion and Call to Action

6.1. From Blind Trust to Verified Blindness

In this work we explored the *Privacy–Auditability Paradox* and the systemic fragility underlying the current pursuit of unconditional, un-auditable opacity: while the trustless paradigm of blind SecAgg ensures data sovereignty, it has inadvertently created a regulatory vacuum that empowers adversarial actors and hinders legal compliance. We reject the fatalistic view that privacy and accountability must be mutually exclusive. Through the framework of **Control-able Secure Aggregation**, we synthesize mathematical confidentiality with rigorous governance: CSA does not tear down the walls of privacy but installs cryptographic doors, transparent, policy-controlled, and mathematically protected, that let systems prove their integrity without revealing their secrets. The era of *Blind Secure Aggregation* is ending; the era of *Verified and Controlled Blindness* should begin.

6.2. A Call for Co-Design: The OpenCSA Initiative

To turn CSA from concept into industry standard, the community must break down the methodological silos that divide the field: cryptographers optimizing primitive efficiency (e.g., ring-LWE operations) in isolation from ML researchers refining convergence rates (e.g., AdamW) is no longer sustainable.

We propose a holistic *Cryptographic-ML Co-Design* roadmap along two axes: *ZK-Friendly Neural Architectures* (e.g., square activations replacing ReLU) and *Standardized Policy Languages* mapping regulatory requirements (e.g., GDPR Art. 22) onto ABFE constraints, institutionalized via a proposed *OpenCSA Consortium* for cross-jurisdictional interoperability. The field should also evolve toward a *Trustworthy Pareto Frontier* that treats *Audit Success Rate* and attack-detection rate as first-class metrics.

Acknowledgements

This work was supported by the National Natural Science Foundation of China under Grant No. 62302022. The authors thank the anonymous ICML reviewers for their constructive feedback that substantially improved this work.

Impact Statement

This paper presents work whose goal is to advance the field of machine learning. There are many potential societal consequences of our work, none of which we feel must be specifically highlighted here.

References

- Abdalla, M., Catalano, D., Gay, R., and Ursu, B. Inner-product functional encryption with fine-grained access control. In *International Conference on the Theory and Application of Cryptology and Information Security*, pp. 467–497. Springer, 2020.
- Bagdasaryan, E., Veit, A., Hua, Y., Estrin, D., and Shmatikov, V. How to backdoor federated learning. In *International Conference on Artificial Intelligence and Statistics*, pp. 2938–2948. PMLR, 2020.
- Bell, J., Gascón, A., Lepoint, T., Li, B., Meiklejohn, S., Raykova, M., and Yun, C. {ACORN}: input validation for secure aggregation. In *32nd USENIX Security Symposium (USENIX Security 23)*, pp. 4805–4822, 2023.
- Bell, J. H., Bonawitz, K. A., Gascón, A., Lepoint, T., and Raykova, M. Secure single-server aggregation with (poly) logarithmic overhead. In *Proceedings of the 2020 ACM SIGSAC conference on computer and communications security*, pp. 1253–1269, 2020.
- Benhamouda, F., Halevi, S., Krawczyk, H., Miao, A., and Rabin, T. Threshold cryptography as a service (in the multiserver and yoso models). In *Proceedings of the 2022 ACM SIGSAC conference on computer and communications security*, pp. 323–336, 2022.
- Boenisch, F., Dziedzic, A., Schuster, R., Shamsabadi, A. S., Shumailov, I., and Papernot, N. When the curious abandon honesty: Federated learning is not private. In *2023 IEEE 8th European Symposium on Security and Privacy (EuroS&P)*, pp. 175–199. IEEE, 2023. doi: 10.1109/EuroSP57164.2023.00020.
- Bonawitz, K., Ivanov, V., Kreuter, B., Marcedone, A., McMahan, H. B., Patel, S., Ramage, D., Segal, A., and Seth, K. Practical secure aggregation for privacy-preserving machine learning. In *Proceedings of the 2017 ACM SIGSAC Conference on Computer and Communications Security*, pp. 1175–1191, 2017.
- Boneh, D. and Freeman, D. M. Homomorphic signatures for polynomial functions. In *annual international conference on the theory and applications of cryptographic techniques*, pp. 149–168. Springer, 2011.
- Boyen, X. Attribute-based functional encryption on lattices. In *Theory of cryptography conference*, pp. 122–142. Springer, 2013.
- Cao, X., Jia, J., and Gong, N. Z. Provably secure federated learning against malicious clients. *Proceedings of the AAAI Conference on Artificial Intelligence*, 35(8):6885–6893, 2021. doi: 10.1609/aaai.v35i8.16849.
- Chen, J., Yan, H., Liu, Z., Zhang, M., Xiong, H., and Yu, S. When federated learning meets privacy-preserving computation. *ACM Computing Surveys*, 56(12):1–36, 2024.
- Chotard, J., Dufour Sans, E., Gay, R., Phan, D. H., and Pointcheval, D. Decentralized multi-client functional encryption for inner product. In *Advances in Cryptology—ASIACRYPT 2018*, pp. 703–732. Springer, 2020.
- European Parliament and Council of the European Union. Regulation (EU) 2024/1689 of the European Parliament and of the Council of 13 June 2024 laying down harmonised rules on artificial intelligence (artificial intelligence act). Official Journal of the European Union, OJ L, 2024/1689, 12 July 2024, 2024. URL <http://data.europa.eu/eli/reg/2024/1689/oj>. Article 15: Accuracy, robustness and cybersecurity.
- Garg, S., Goel, A., Jain, A., Policharla, G.-V., and Sekar, S. {zkSaaS}:{Zero-Knowledge}{SNARKs} as a service. In *32nd USENIX Security Symposium (USENIX Security 23)*, pp. 4427–4444, 2023.
- Han, S., Wu, W., Buyukates, B., Jin, W., Yao, Y., Zhang, Q., Avestimehr, S., and He, C. Kick bad guys out! conditionally activated anomaly detection in federated learning with zero-knowledge proof verification. In *Workshop on Attack Provenance, Reasoning, and Investigation for Security in the Monitored Environment (PRISM)*, San Diego, CA, USA, 2026. Internet Society. Co-located with the Network and Distributed System Security Symposium (NDSS).
- Jain, A., Lin, H., and Luo, J. On the optimal succinctness and efficiency of functional encryption and attribute-based encryption. In *Annual International Conference on the Theory and Applications of Cryptographic Techniques*, pp. 479–510. Springer, 2023.
- Jin, W., Yao, Y., Han, S., Joe-Wong, C., Ravi, S., Avestimehr, S., and He, C. FedML-HE: An efficient homomorphic-encryption-based privacy-preserving federated learning system. In *International Workshop on Federated Learning in the Age of Foundation Models in Conjunction with NeurIPS 2023 (FL@FM-NeurIPS’23)*, 2023. URL <https://openreview.net/forum?id=PuYD0fh5aq>.

- Johnson, R., Molnar, D., Song, D., and Wagner, D. Homomorphic signature schemes. In Preneel, B. (ed.), *Topics in Cryptology — CT-RSA 2002*, volume 2271 of *Lecture Notes in Computer Science*, pp. 244–262, San Jose, CA, USA, 2002. Springer Berlin Heidelberg. doi: 10.1007/3-540-45760-7_17.
- Laufer, E., Ozdemir, A., and Boneh, D. zkpi: Proving lean theorems in zero-knowledge. In *Proceedings of the 2024 on ACM SIGSAC Conference on Computer and Communications Security*, pp. 4301–4315, 2024.
- Li, Y., Wei, J., Guo, F., Susilo, W., and Chen, X. Robust decentralized multi-client functional encryption: motivation, definition, and inner-product constructions. In *International Conference on the Theory and Application of Cryptology and Information Security*, pp. 134–165. Springer, 2023.
- Lycklama, H., Burkhalter, L., Viand, A., Küchler, N., and Hithnawi, A. RoFL: Robustness of secure federated learning. In *2023 IEEE Symposium on Security and Privacy (SP)*, pp. 453–476. IEEE, 2023. doi: 10.1109/SP46215.2023.10179400.
- Lyu, L., Yu, H., Ma, X., Chen, C., Sun, L., Zhao, J., Yang, Q., and Yu, P. S. Privacy and robustness in federated learning: Attacks and defenses. *IEEE transactions on neural networks and learning systems*, 35(7):8726–8746, 2022.
- Ma, R., Hwang, K., Li, M., and Miao, Y. Trusted model aggregation with zero-knowledge proofs in federated learning. *IEEE Transactions on Parallel and Distributed Systems*, 2024.
- Ma, Y., Woods, J., Angel, S., Polychroniadou, A., and Rabin, T. Flamingo: Multi-round single-server secure aggregation with applications to private federated learning. In *2023 IEEE Symposium on Security and Privacy (SP)*, pp. 477–496. IEEE, 2023.
- Mansouri, M., Önen, M., Ben Jaballah, W., and Conti, M. SoK: Secure aggregation based on cryptographic schemes for federated learning. *Proceedings on Privacy Enhancing Technologies*, 2023(1):140–157, 2023. doi: 10.56553/popets-2023-0009.
- Nguyen, D. D., Phan, D. H., and Pointcheval, D. Verifiable decentralized multi-client functional encryption for inner product. In *International Conference on the Theory and Application of Cryptology and Information Security*, pp. 33–65. Springer, 2023.
- Nguyen, K., Phan, D. H., and Pointcheval, D. Multi-client functional encryption with fine-grained access control. In *International Conference on the Theory and Application of Cryptology and Information Security*, pp. 95–125. Springer, 2022a.
- Nguyen, T. D., Rieger, P., Chen, H., Yalame, H., Möllering, H., Fereidooni, H., Marchal, S., Miettinen, M., Mirhoseini, A., Zeitouni, S., et al. {FLAME}: Taming backdoors in federated learning. In *31st USENIX Security Symposium (USENIX Security 22)*, pp. 1415–1432, 2022b.
- Nguyen, T. T., Huynh, T. T., Ren, Z., Nguyen, P. L., Liew, A. W.-C., Yin, H., and Nguyen, Q. V. H. A survey of machine unlearning. *ACM Transactions on Intelligent Systems and Technology*, 16(5):1–46, 2025.
- Pal, T. and Dutta, R. Attribute-based access control for inner product functional encryption from lwe. In *International Conference on Cryptology and Information Security in Latin America*, pp. 127–148. Springer, 2021.
- Qian, X., Li, H., Hao, M., Xu, G., Wang, H., and Fang, Y. Decentralized multi-client functional encryption for inner product with applications to federated learning. *IEEE Transactions on Dependable and Secure Computing*, 21(6):5781–5796, 2024.
- Qu, Y., Uddin, M. P., Gan, C., Xiang, Y., Gao, L., and Yearwood, J. Blockchain-enabled federated learning: A survey. *ACM Computing Surveys*, 55(4):1–35, 2022.
- Rathee, M., Shen, C., Wagh, S., and Popa, R. A. ELSA: Secure aggregation for federated learning with malicious actors. In *2023 IEEE Symposium on Security and Privacy (SP)*, pp. 1961–1979. IEEE, 2023. doi: 10.1109/SP46215.2023.10179468.
- So, J., Güler, B., and Avestimehr, A. S. Byzantine-resilient secure federated learning. *IEEE Journal on Selected Areas in Communications*, 39(7):2168–2181, 2021. doi: 10.1109/JSAC.2020.3041404.
- Tian, Z., Cui, L., Liang, J., and Yu, S. A comprehensive survey on poisoning attacks and countermeasures in machine learning. *ACM Computing Surveys*, 55(8):1–35, 2022.
- Uddin, M. P., Xiang, Y., Hasan, M., Bai, J., Zhao, Y., and Gao, L. A systematic literature review of robust federated learning: Issues, solutions, and future research directions. *ACM Computing Surveys*, 57(10):1–62, 2025.
- Wang, R., Hazay, C., and Venkatasubramanian, M. Ligetron: Lightweight scalable end-to-end zero-knowledge proofs post-quantum zk-snarks on a browser. In *2024 IEEE Symposium on Security and Privacy (SP)*, pp. 1760–1776. IEEE, 2024a.

- Wang, Z., Ma, J., Wang, X., Hu, J., Qin, Z., and Ren, K. Threats to training: A survey of poisoning attacks and defenses on machine learning systems. *ACM Computing Surveys*, 55(7):1–36, 2022.
- Wang, Z., Dong, N., Sun, J., Knottenbelt, W., and Guo, Y. zkfl: Zero-knowledge proof-based gradient aggregation for federated learning. *IEEE Transactions on Big Data*, 11(2):447–460, 2024b.
- Xie, C., Huang, K., Chen, P.-Y., and Li, B. DBA: Distributed backdoor attacks against federated learning. In *International conference on learning representations*, 2019.
- Xie, C., Chen, M., Chen, P.-Y., and Li, B. CRFL: Certifiably robust federated learning against backdoor attacks. In *International conference on machine learning*, pp. 11372–11382. PMLR, 2021.
- Xu, R., Li, B., Li, C., Joshi, J. B., Ma, S., and Li, J. TAPFed: Threshold secure aggregation for privacy-preserving federated learning. *IEEE Transactions on Dependable and Secure Computing*, 21(5):4309–4323, 2024.
- Zhu, J., Cao, J., Saxena, D., Jiang, S., and Ferradi, H. Blockchain-empowered federated learning: Challenges, solutions, and future directions. *ACM Computing Surveys*, 55(11):1–31, 2023.